



A Protective Middleware Between Employees and AI Tools

Concept and Technical Report

Track 02: Cybersecurity and Defensive Technologies

Prepared by:

Teef Saleh Alghamdi - Shahad Helal Alghamdi

28 September 2026

Contents

1. Executive summary
 2. The problem
 3. Threat model
 4. Solution overview
 5. Architecture
 6. Detection engine
 7. Policy actions
 8. Security of SADIN itself
 9. Deployment model
 10. Employee experience
 11. Compliance and governance
 12. Existing approaches and how SADIN differs
 13. Prototype, demonstration and results
 14. Limitations and residual risk
 15. Roadmap
 16. Alignment with SAIF 2026
 17. Team
 18. Glossary
 19. References
-

1. Executive summary

Generative AI tools are now part of everyday work. An employee stuck on a problem pastes a firewall configuration, uploads an internal document or pastes a screenshot of an admin console, and asks an AI assistant for help. The employee means no harm, but the data has left the organization and now sits with a third party. From there it can reach attackers through a stolen AI account, a chat shared by link, or the vendor's own retention and breaches. Most organizations face a poor choice: block AI and push its use onto personal devices, or allow it and accept the risk.

SADIN (سادن) is a protective middleware between employees and AI tools. Everything an employee sends to an AI tool passes through it first. Secrets, internal network details and account identifiers are replaced with placeholders, classified documents are stopped, and every decision is logged. The employee still gets an answer; the organization's secrets never reach the AI vendor.

SADIN is designed as one policy engine with three enforcement points: an **Agent** on managed devices (a force-installed browser extension, and an endpoint agent in a later phase), an **Identity** layer that ties AI use to the employee's work account, and a **Gateway** for unmanaged devices. All inspection runs on the employee's device or on the organization's own server, never in a third-party cloud, so SADIN does not become another place where the data ends up.

A working prototype has been built and tested: a Chrome and Edge extension (Manifest V3) with one shared detection engine and an on-premises inspection service that reads screenshots with Arabic and English OCR. It intercepts typed, pasted and dragged text, text-file uploads and images, in Arabic and English. On test sets that were frozen before the run and not tuned afterwards, it measured:

86.3% sensitive items caught in text (44 of 51)	0 of 50 false positives on clean business prompts	95.8% screenshot values masked (69 of 72)	36 of 36 Arabic items caught (1 false positive in 40)
--	--	--	--

The test sets are synthetic and were written by the team, so these figures show that the approach works on realistic workplace phrasing; they do not show performance on an organization's real traffic. A pilot on real, consented traffic is the next step. Section 13 gives the full method, and every number in this report can be reproduced from the published source and raw results.

2. The problem

2.1 Context

- **The risk is inside the organization.** Employees who turn to AI for help send the organization's secrets out themselves, usually without realizing it.
- **AI use at work is broad and largely unmanaged ("shadow AI").** Employees use personal accounts on public AI tools for real work.
- **What is sent stays with the vendor.** Consumer AI services such as ChatGPT keep the chat history by default [3], and once content is sent the organization cannot recall it.
- **Blocking does not work.** When AI sites are blocked at the firewall, use moves to personal phones and laptops, and the organization loses both visibility and the productivity gain.

2.2 How data sent to AI reaches attackers

Once an employee sends data to a public AI tool, the organization no longer controls who can see it. Documented incidents show three paths, none of which requires the attacker to break into the organization.

Path	What happens	Documented example
Stolen AI accounts	AI tools keep the full chat history. Infostealer malware takes saved logins from the browser, and whoever buys the login can read everything the employee sent.	Group-IB identified 101,134 infostealer-infected devices with saved ChatGPT credentials in logs traded between June 2022 and May 2023 [3], and more than 225,000 logs containing ChatGPT credentials offered for sale between January and October 2023 [4].
Chats shared by link	A shared conversation becomes a public web page. When the sharer opted to make it discoverable, search engines could index it.	In July 2025, Fast Company found nearly 4,500 shared ChatGPT conversations in Google results; OpenAI removed the discoverability option shortly afterwards [6].
Retention by the vendor	Submitted content is stored by the vendor and exposed to that vendor's own incidents and legal processes.	In March 2023, Samsung semiconductor engineers entered source code and meeting content into ChatGPT in three separate incidents within about 20 days; Samsung then banned generative AI tools on company devices from May 2023 [5].

2.3 What SADIN treats as sensitive

Sensitive here means data that must never leave the organization because an attacker who finds it can use it against the organization. SADIN deliberately focuses on the organization's own secrets rather than on general personal data such as phone numbers or bank account numbers.

Category	Examples	Why it must not leave	Prototype
Classified documents	Content marked Top Secret, Secret or Restricted; scanned memos carrying an Arabic classification stamp	Classified under the NDMO levels; cannot be recalled once sent	Detected (6 detectors)
Credentials and secrets	Passwords, API keys, tokens, private keys, pre-shared keys, .env values, connection strings	Direct access to company systems	Detected (24)
Network and infrastructure details	Internal IP addresses and ranges, hostnames, ports, MAC addresses, the organization's public ranges	Gives an attacker a map of the network	Detected (16)

Category	Examples	Why it must not leave	Prototype
Account identifiers	Work email addresses, DOMAIN\user accounts, usernames, employee IDs	Starting point for phishing and account takeover	Detected (6)
Security findings and logs	Scanner output, CVEs described as unpatched, penetration-test and incident report titles	Shows an attacker which weaknesses are open	Detected and flagged (4)
Screenshots of internal systems	Admin consoles, SOC dashboards, HR and ERP screens	Expose several of the above at once	OCR, then the same detectors
Source code and configuration	Internal repositories, schemas, deployment scripts	Intellectual property and attack surface	Secrets inside code are detected; code as such is not (Phase 2)

2.4 Why this matters in Saudi Arabia

- The National Cybersecurity Authority's Essential Cybersecurity Controls (ECC-2:2024) require data and information protection, identity and access management, and cybersecurity event logging and monitoring [1].
- The National Data Management Office's Data Classification Policy defines four levels, Top Secret, Secret, Restricted and Public, and requires classified data to be handled according to its level [2].
- Saudi employees write to AI tools in Arabic, in English, or in both within one sentence, and often use Arabic-Indic digits and colloquial terms. A control that only understands English misses much of what they actually send.

2.5 The gap

Cloud DLP and CASB products already cover AI tools, and some offer Arabic support. What we did not find in the tools we reviewed is one product that combines four properties:

- reading Arabic content, including classification stamps on scanned pages; inspecting on the organization's own premises rather than in the vendor's cloud.
- redacting the sensitive part of text and images instead of blocking the whole request.
- mapping its policy to NCA ECC-2:2024 and the NDMO levels.

This is a gap we observed in our review, not a claim about every product on the market.

3. Threat model

Asset: the organization's secrets listed in Section 2.3.

Threat: an employee, usually without bad intent, sends them to a generative AI tool.

Out of scope: a determined insider deliberately evading controls, which is an insider-threat problem rather than an accidental-leakage problem.

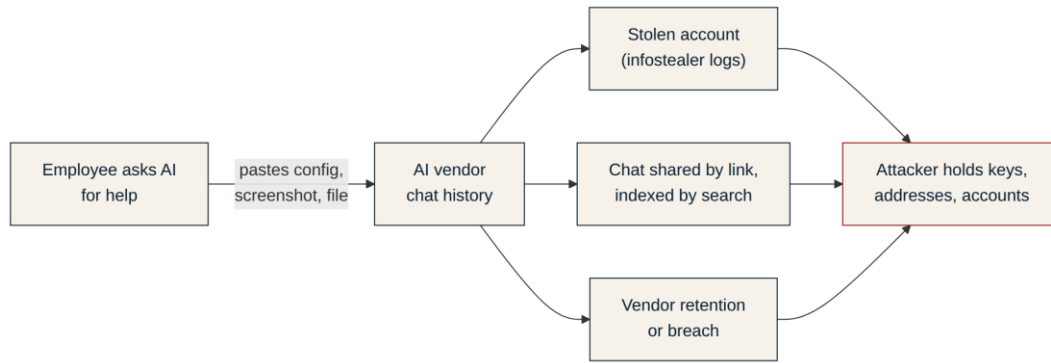


Figure 1. How data sent to an AI tool reaches an attacker without any intrusion into the organization.

Channel	Example	Covered by	State
Typed text	A password typed into the prompt	Extension, checked at send time	Built
Pasted and dragged text	A router configuration	Extension	Built
Text-format file upload	.env, .conf, .log, source files	Extension; a sanitized copy is uploaded	Built
Images and screenshots	A SOC dashboard, a scanned memo	Extension and on-premises OCR	Built
PDF, Office and archives	A contract, an Excel export	Blocked whole under the fail-closed rule; parsing in Phase 2	Partial
Desktop AI apps, IDE assistants, voice	An IDE assistant, dictated notes	Endpoint agent	Phase 2
Personal AI account on a work device	Personal login on a public AI site	Identity layer	Phase 3
Company data on a personal device	A home laptop	Conditional access; Gateway	Phases 3 and 4
Phone camera, re-typing	Photographing the screen	Not technically coverable	Policy and awareness

Assumptions. The organization manages its endpoints (domain-joined or MDM-enrolled), uses a central identity provider such as Microsoft Entra ID or Google Workspace, and has or will adopt a data classification scheme.

4. Solution overview

SADIN stands between the employee and every AI tool, and everything the employee sends passes through it. AI stays available; the point is to make its use visible and safe, so that every request is inspected, decided by policy and logged.

4.1 Design principles

- **Allow AI and protect the data.** The default is that work continues.
- **Inspect locally.** Content is inspected on the device or on the organization's own server. A middleware that shipped the data to another cloud would recreate the problem it exists to solve.
- **Redact before blocking.** Remove the sensitive part and let the rest through.
- **Fail closed.** Content SADIN cannot inspect is blocked, not waved through.
- **Log decisions, not content.** The log records who, which tool, which channel, which action and which data classes, never the text, the image or the matched values.
- **People stay in charge.** Policies and exceptions are approved by named people; SADIN applies them.

4.2 One policy engine, three enforcement points

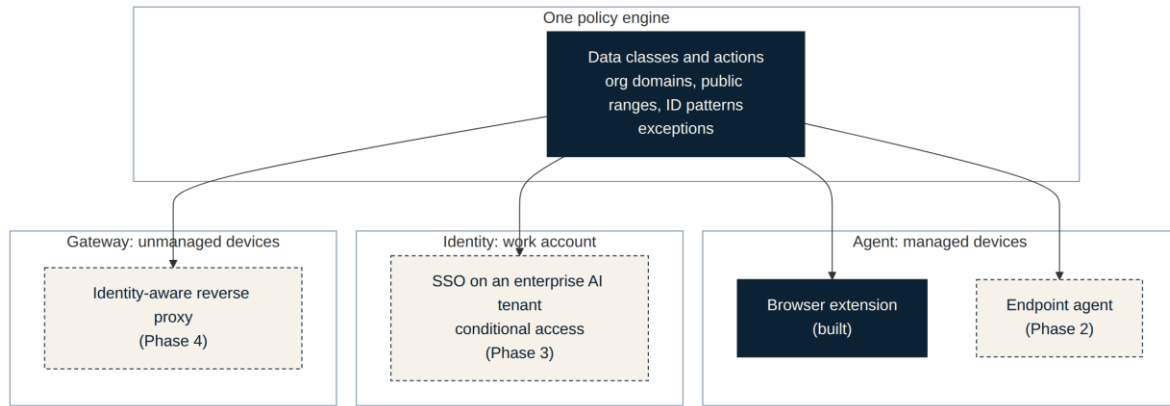


Figure 2. One policy engine and three enforcement points. Solid: built in the prototype. Dashed: designed, planned for later phases.

Enforcement point	What it covers	State
Agent: browser extension	Typed, pasted and dragged text, file uploads and images in AI chat sites on managed Chrome and Edge browsers	Built and tested
Agent: endpoint agent	Desktop AI apps, IDE assistants, the clipboard, Office and PDF parsing, voice, device posture	Designed (Phase 2)
Identity	AI use only through the work account on an enterprise AI tenant; company data only on compliant devices; personal AI accounts blocked on work devices	Designed (Phase 3)
Gateway	Sessions from unmanaged devices routed through an identity-aware reverse proxy applying the same policy	Designed (Phase 4)

4.3 One scenario, with and without SADIN

Step	Without SADIN	With SADIN (prototype)
1. A VPN tunnel keeps dropping; the engineer opens an AI tool	Any tool, often a personal account	Same tool; the force-installed extension is present
2. Pastes the router configuration	The configuration, internal addresses and pre-shared key go straight to the vendor	The paste is intercepted on the device before the page receives it
3. Inspection	None	The engine finds the key, the password hash, the addresses, the port, the hostname and the account
4. Decision	None	Policy for credentials, network details and accounts is redact; each value is replaced with a placeholder
5. Sending	Everything is stored in the vendor's chat history	Only the redacted configuration reaches the AI, and the engineer still gets an answer
6. Later	A stolen account or a shared link exposes the configuration	The chat history holds no secrets; the security team sees one logged redaction event

5. Architecture

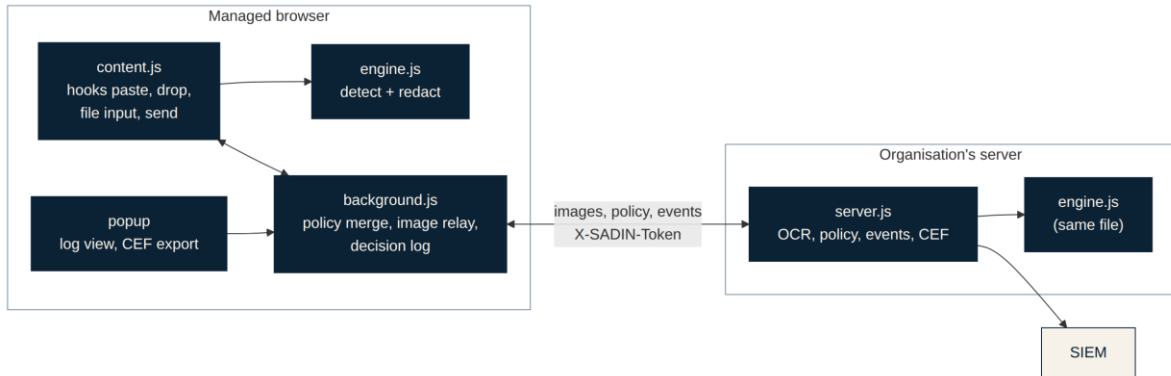


Figure 3. Prototype components. The same engine file runs in the browser and on the inspection service.

5.1 Browser extension (built)

- **Content script** (content.js) runs inside AI tool pages and captures paste, drop, file-input changes and send (Enter or the send button) before the page does. It asks the engine, then inserts the sanitized content, blocks it, or shows a notice.
- **Detection engine** (engine.js): 56 detectors across five data classes, in Arabic and English, in plain JavaScript with no dependencies. It returns findings (class, detector, character span) and a redacted copy.
- **Background worker** (background.js) merges the policy (built-in defaults, then the policy server, then Chrome managed storage set by IT, which wins), relays images to the inspection service, keeps the last 500 decisions locally and forwards each to the server.
- **Popup** shows the inspection service status and recent decisions, and exports the local log in CEF format.

- **Managed settings** (managed_schema.json) define what IT pushes by policy: server address and token, the organization's domains, public ranges and employee ID format, the action per data class, and fail-closed behavior.

The extension is configured for ChatGPT, Claude, Gemini, Copilot, Perplexity, DeepSeek, Mistral and Poe, and for the local test page used in the demonstration.

5.2 On-premises inspection service (built)

A Node.js service with no npm dependencies. It reads screenshots with Tesseract OCR in Arabic and English [9], runs a second pass over colored ink to read boxed classification stamps, applies the same engine, and returns the action and the rectangles to mask; it never echoes the recognized text. It also serves the policy, receives decision events and exports them as CEF for the SIEM. Browser requests are accepted only from the SADIN extension, and a shared token is required in deployment (Section 8).

5.3 Endpoint agent (designed, Phase 2)

Covers what a browser extension cannot see: desktop AI applications, IDE assistants and the clipboard. It hosts heavy local modules (document parsing, speech-to-text) and reports device posture. In Manifest V3, blocking web-request interception remains available to extensions installed by policy [7], which gives the Agent a network-level backstop that consumer-installed extensions do not have.

5.4 Identity (designed, Phase 3)

- AI access through the employee's work account via single sign-on on an enterprise AI tenant whose terms exclude business data from model training and which exposes admin and audit controls.
- Conditional Access (Microsoft Entra ID, or context-aware access in Google Workspace) keeps company email, files and systems reachable only from compliant devices, so a personal device has no company data to paste.
- Personal AI accounts blocked on managed devices through tenant restrictions and the extension.

5.5 Gateway (designed, Phase 4)

For organizations that allow access from unmanaged devices, sessions are routed through an identity-aware reverse proxy that applies the same policy engine to uploads and pasted content.

5.6 Policy and console

In the prototype, policy is a JSON document (per-class actions and the organization's identifiers) delivered by the inspection service and overridden by Chrome managed storage. The decision log is available in the extension popup, in the service's event file and as a CEF feed. A management console with dashboards, per-department views and an exception-approval queue is part of the design and is not built.

6. Detection engine

One file, engine.js, is used by the extension, the inspection service and the test harness, so the evaluation measures the code that runs in the browser.

Data class	Placeholders	Default action	Detectors
CLASSIFIED	CLASSIFIED	Block	6
CREDENTIAL	SECRET, API_KEY, TOKEN, AWS_KEY, AWS_SECRET, PRIVATE_KEY	Redact	24
NETWORK	INTERNAL_IP, ORG_IP, HOSTNAME, PORT, MAC	Redact	16
ACCOUNT	ACCOUNT, EMPLOYEE_ID	Redact	6
SECURITY_FINDING	None (flagged, not replaced)	Warn	4

6.1 How a message is scanned

The same six steps apply to typed, pasted and file text and to the text read from screenshots.

1. **Normalize digits.** Arabic-Indic and Eastern Arabic-Indic digits and the Arabic decimal separator are mapped one-to-one to ASCII. The mapping never changes the text length, so a span found in the normalized copy redacts exactly the right characters in the original.
2. **Detect.** Each detector is a pattern plus, where needed, a validator: ports must be 1 to 65535; IPv4 addresses must parse and fall in a private range or in one of the organization's public ranges; password candidates must mix character classes; placeholders such as "changeme", "\${VAR}" or "****" are rejected; long random strings are tested for entropy.
3. **Resolve overlaps.** The longer finding wins; on a tie the more sensitive class wins.
4. **Decide.** Each class maps to allow, warn, redact or block by policy, and the strictest class present decides the message.
5. **Redact.** Each distinct value gets a numbered placeholder, and a repeated value gets the same placeholder, so the AI can still reason about structure: "ip address [INTERNAL_IP_1] ... host [INTERNAL_IP_2] eq [PORT_1]".
6. **Re-scan.** The redacted output is scanned again and must not trigger anything.

6.2 Arabic

On engine v0.3.1 the Arabic held-out set scored 50.0% (18 of 36). The gaps below were found on the Arabic development set and fixed; on engine v0.4.0 the held-out set scored 36 of 36.

Gap found	Example	Fix
Word boundaries (\b) do not work in Arabic script, so Arabic port phrases were never matched	8443 المنفذ	Explicit "not an Arabic letter" guards instead of \b
Arabic digits were invisible to every numeric pattern	١٠.١٥.٢٠	Digit normalisation before scanning
Colloquial terms for passwords, users and ports	الباسورد، الباس، اليوزر، بورت	Added to the keyword lists, with and without the article
Keyword and value a few words apart	كلمة السر حقت الإيميل:	Up to four Arabic words allowed between keyword and value
Diacritics inside keywords	كلمة المرور	Keywords tolerate diacritics between letters

Gap found	Example	Fix
Lists of ports	المنافذ ٢١ و ٢٢ و ٣٣٨٩	A list detector that redacts every port in the list
Arabic wording around CVEs	لم تُرَفَّع	CVEs next to Arabic vulnerability wording are flagged

6.3 Screenshots and images

1. Small screenshots are upscaled 2x and converted to greyscale when ImageMagick is available.
2. Tesseract 5 with the Arabic and English models returns every word with its position.
3. Colored-ink regions are cropped and read separately, because ordinary page segmentation skips boxed stamps.
4. The recognized text goes through the same engine with an OCR-tolerant option that also recognizes private addresses with one misread octet.
5. The service returns the rectangles behind each finding and the extension paints over them before the image is passed on. A classification marking anywhere blocks the whole image.

6.4 Planned detection (not built)

Office and PDF parsing, Microsoft Purview / MIP sensitivity labels as the first signal, document fingerprinting of registered classified files, and an ML classifier for broader coverage are part of the design for Phase 2. They are not part of the measured results.

7. Policy actions

Action	When	What the employee sees (prototype)
Allow	Nothing sensitive found, or the class is set to allow	Nothing; the request proceeds
Redact	Credentials, network details or account identifiers inside otherwise legitimate content	The values are replaced with placeholders (image regions are masked) and a bilingual notice lists what was replaced. For typed text the send is paused so the employee can review the redacted message and send again.
Warn	Security findings by default, or any class set to warn	A notice explains what was found; the content is not changed and the event is logged
Block	Classification markings by default, or any class set to block	Nothing is sent; the notice gives the reason
Fail closed	Content that cannot be inspected: PDF, Office and archive files, and images while the inspection service is unreachable	Blocked, with the reason shown

Every notice has a **Request exception** button. The employee writes a business justification, which is logged for the security team; the content itself is still not sent. Requiring a justification before a warned request proceeds, and an approval workflow, are part of the design and not built.

8. Security of SADIN itself

A security control has to withstand the pages and people it sits between. A review of the prototype on 26 September 2026 found that the inspection service accepted requests from any web page, so a site an employee visited could read the decision log or write fake events, and that a line break in a logged field could forge an extra line in the CEF export. Both were fixed and retested.

Property	How the prototype achieves it
Only SADIN can call the inspection service	Browser requests from any origin other than the SADIN extension are refused (HTTP 403). Allowed extension IDs can be pinned with SADIN_EXTENSION_IDS.
Authenticated in deployment	With SADIN_TOKEN set, every endpoint except /health requires the X-SADIN-Token header, compared in constant time. IT pushes the same value to the extension as the managed serverToken setting.
Log entries cannot be forged	Control characters are stripped from every logged field, actions are limited to known values, and CEF values are escaped.
No content in the log	Events carry user, tool, channel, action, data classes and counts only.
Cannot be removed by the user	The extension is force-installed by enterprise policy; users cannot disable or remove a policy-installed extension.
Fails safe	Images are blocked when the service is unreachable; unparseable files are blocked by default.
Small attack surface	No third-party npm dependencies in the extension or the service.

Remaining deployment tasks: TLS in front of the service when it is reached over the network, and role-based access to the event file.

9. Deployment model

1. **Inspection service.** Run on an internal VM with Node.js 18+, Tesseract 5 (ara and eng) and optionally ImageMagick, with SADIN_TOKEN and SADIN_EXTENSION_IDS set, behind TLS.
2. **Extension.** Packaged and force-installed on Chrome and Edge with the ExtensionInstallForcelist policy through Group Policy, Intune, Jamf or Google Admin.
3. **Managed settings.** Server address and token, the organisation's domains, public address ranges and employee ID format, and the action per data class, pushed through the browser's third-party extension policy.
4. **Side doors.** Application control (AppLocker or WDAC) allows only managed browsers; conditional access keeps company data on managed devices; employees are given an enterprise AI tenant through their work account.

9.1 Staged rollout

Stage	Setting	Effect
Observe (2 to 4 weeks)	Every class set to warn	Nothing is changed; findings are shown and logged, and domains, ranges and ID patterns are tuned against real false positives
Protect	Credentials, network details and accounts set to redact	Secrets are replaced; work continues
Enforce	Classified content set to block	Classified content is stopped

The CEF feed goes to the SIEM from the first day, so the security team sees which data classes leak most and from which teams.

10. Employee experience

- Most requests pass silently. When something is replaced, a short notice in Arabic and English says what was removed and why.
- The redacted request still reaches the AI, so the employee gets help with the task.
- A one-click exception request exists for legitimate edge cases.
- An acceptable-use policy signed at onboarding states the rules: AI use for work is allowed; sending classified company data to any AI tool is not; personal AI accounts are not to be used for work. Employees are told what the decision log records.

11. Compliance and governance

SADIN is a technical control that supports the requirements below; it does not make an organization compliant on its own.

11.1 NCA Essential Cybersecurity Controls (ECC-2:2024)

ECC-2:2024 subdomain	How SADIN supports it	State
2-7 Data and Information Protection	Classification-aware control of data leaving through AI tools: block, redact or warn per data class	Built
2-12 Cybersecurity Event Logs and Monitoring Management	Every decision logged centrally with user, tool, channel, action and data classes; CEF export to the SIEM	Built
2-2 Identity and Access Management	AI use tied to the work identity; SSO on an enterprise AI tenant with conditional access	Identity in the log built; SSO designed
2-6 Mobile Devices Security	Company data kept on managed devices; Gateway for unmanaged devices	Designed
Domain 4: Third-Party and Cloud Computing Cybersecurity (4-1, 4-2)	Controlled use of external AI services; inspection on premises, never in another cloud	On-premises inspection built
1-10 Cybersecurity Awareness and Training Program	Bilingual notices that explain, at the moment it happens, what was removed and why	Built

11.2 NDMO data classification

NDMO level	Target policy	Prototype default
Top Secret (سري للغاية)	Block	Block
Secret (سري)	Block	Block
Restricted (مقيّد)	Redact, or allow with a justification	Block (stricter)
Public (عام)	Allow	Allow

The prototype blocks every classification marking it finds, which is stricter than the target policy for Restricted content. Credentials, internal network details and account identifiers are redacted whatever the document's level.

11.3 Human oversight and employee privacy

- Policies are written and approved by the security and data-governance teams; SADIN never decides a document's classification on its own. It reads the markings people put there and applies the policy people wrote.
- Exceptions are requested with a business justification and approved by a named owner.
- The decision log holds metadata only, is kept on premises with role-based access, and is disclosed to employees.

12. Existing approaches and how SADIN differs

Existing approaches include cloud DLP and CASB/SSE suites, browser-security extensions and AI-specific DLP services. In the tools we reviewed we saw one or more of these limitations: limited reading of Arabic classification stamps on scanned pages; inspection in the vendor's cloud, which sends the data to another

third party; block-or-allow behavior with little redaction of images; and enterprise-only pricing and complexity that small public entities and SMEs find hard to adopt.

Capability	Typical existing tools (as reviewed)	SADIN
Arabic OCR and Arabic classification stamps	Not found in the tools we reviewed	Built and tested
Where inspection runs	Vendor cloud	Device or on premises
Redaction of images	Limited	Sensitive regions masked (built)
Redaction inside Office and PDF files	Varies	Phase 2 (blocked whole today)
Desktop AI apps and voice	Often browser only	Endpoint agent (Phase 2)
NCA ECC and NDMO mapping	Generic	Mapped by design

13. Prototype, demonstration and results

13.1 What was built

Component	State	Source
Browser extension (Chrome and Edge, Manifest V3)	Working	extension/
Detection and redaction engine v0.4.0, Arabic and English, 56 detectors	Working	extension/src/engine.js
On-premises inspection service: OCR, stamp pass, policy, event log, CEF export, access control	Working	server/server.js
Local test page that imitates an AI chat and shows what the vendor receives	Working	demo/
Evaluation harness, frozen test sets, raw results, real-browser test	Working	eval/
Endpoint agent, ML classifier, document parsing, enterprise tenant integration, Gateway, console	Not built (design)	Sections 5 and 15

13.2 Demonstration

The demonstration runs on the local test page, so nothing leaves the machine. The right-hand panel shows exactly what the AI vendor would receive.

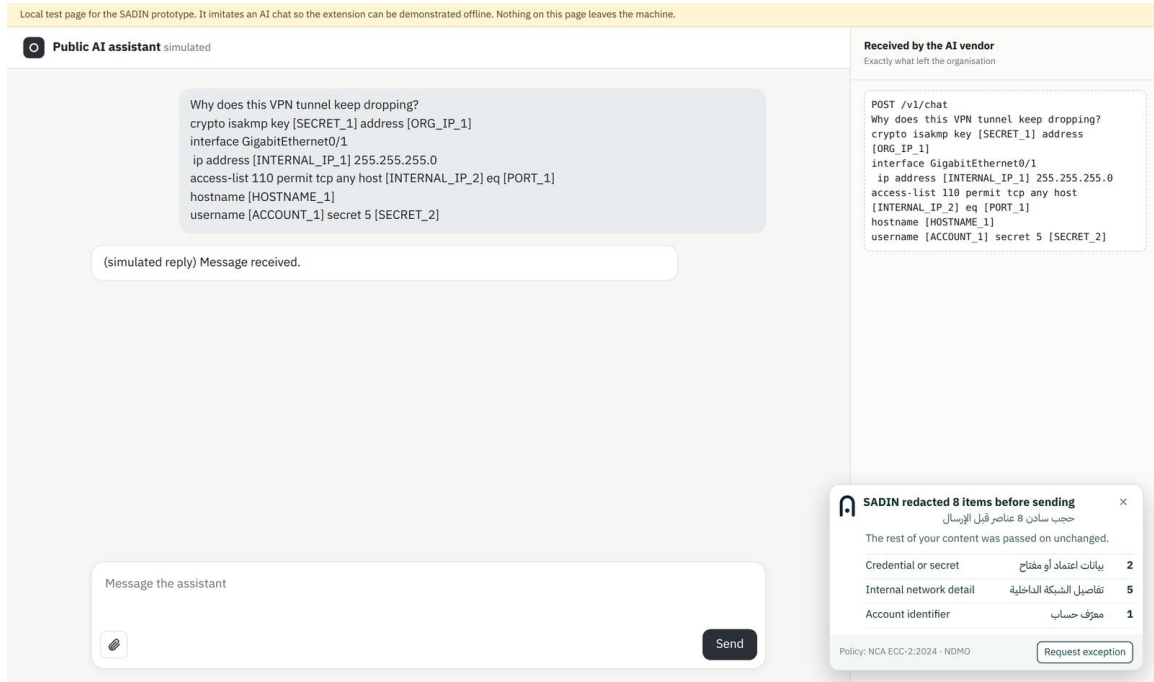


Figure 4. A router configuration is pasted. The pre-shared key, the password hash, the organization's public address, both internal addresses, the port, the hostname and the account are replaced; the question still reaches the AI.

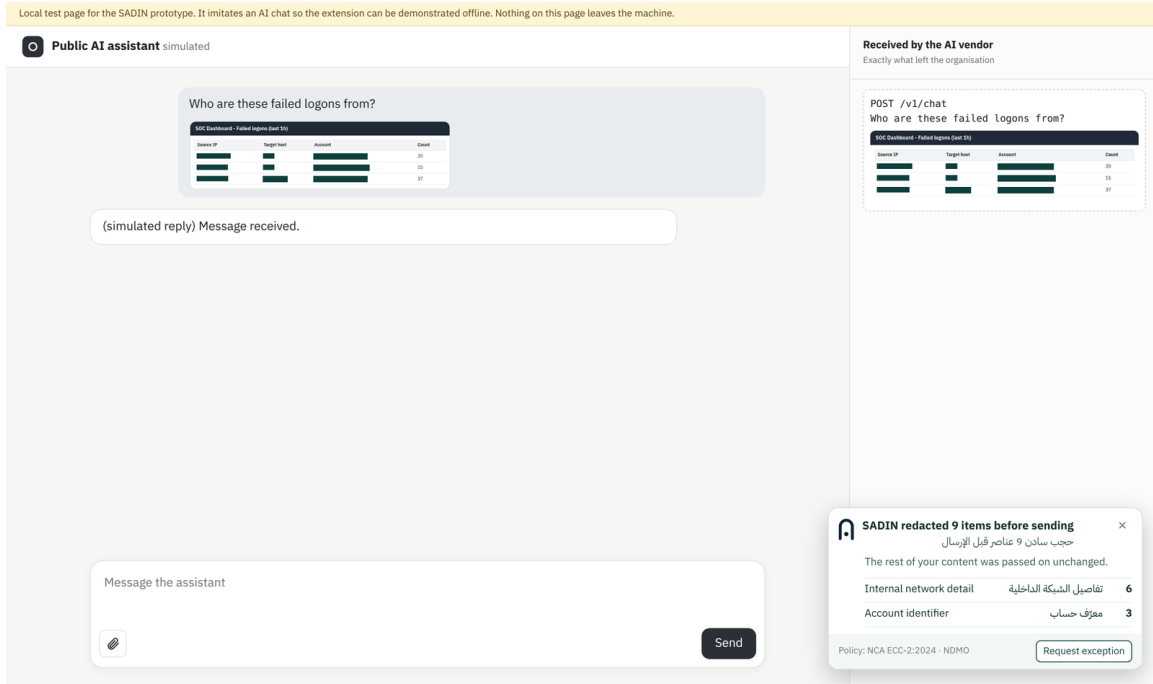


Figure 5. A SOC dashboard screenshot is pasted. The on-premises service reads it with OCR and the sensitive cells are masked in the image. One short hostname (dc04) was missed, as reported in Section 13.4.

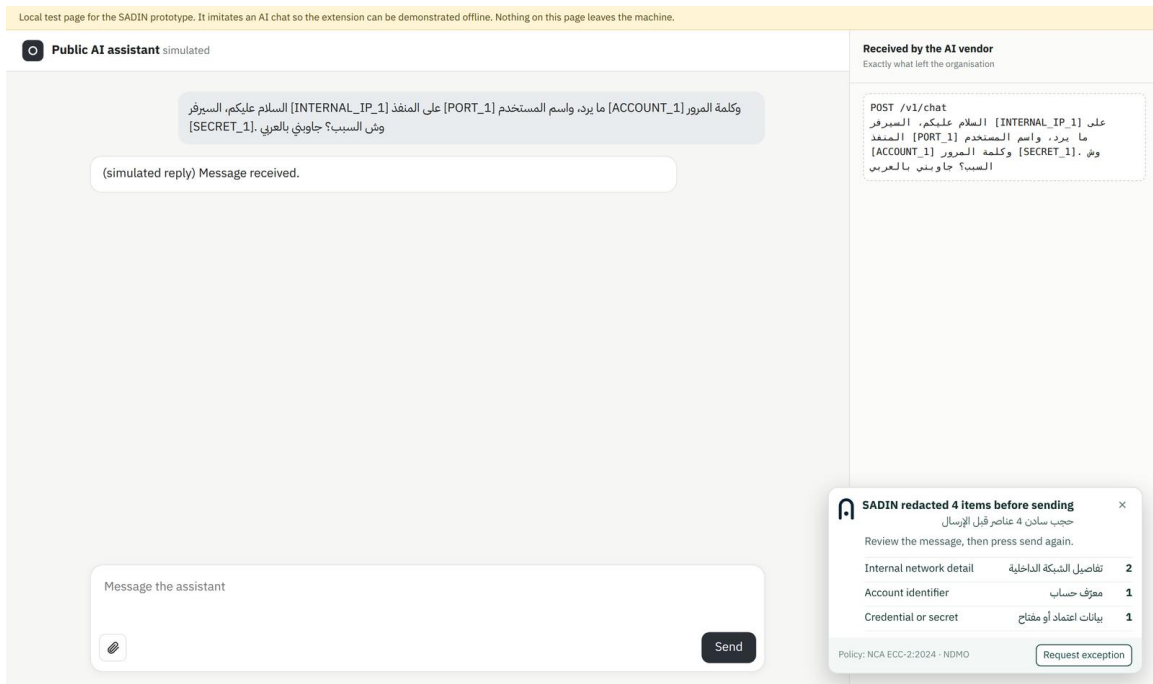


Figure 6. An Arabic request with an IP address in Arabic-Indic digits, a port, a username and a password. All four are replaced and the Arabic question reaches the AI intact.

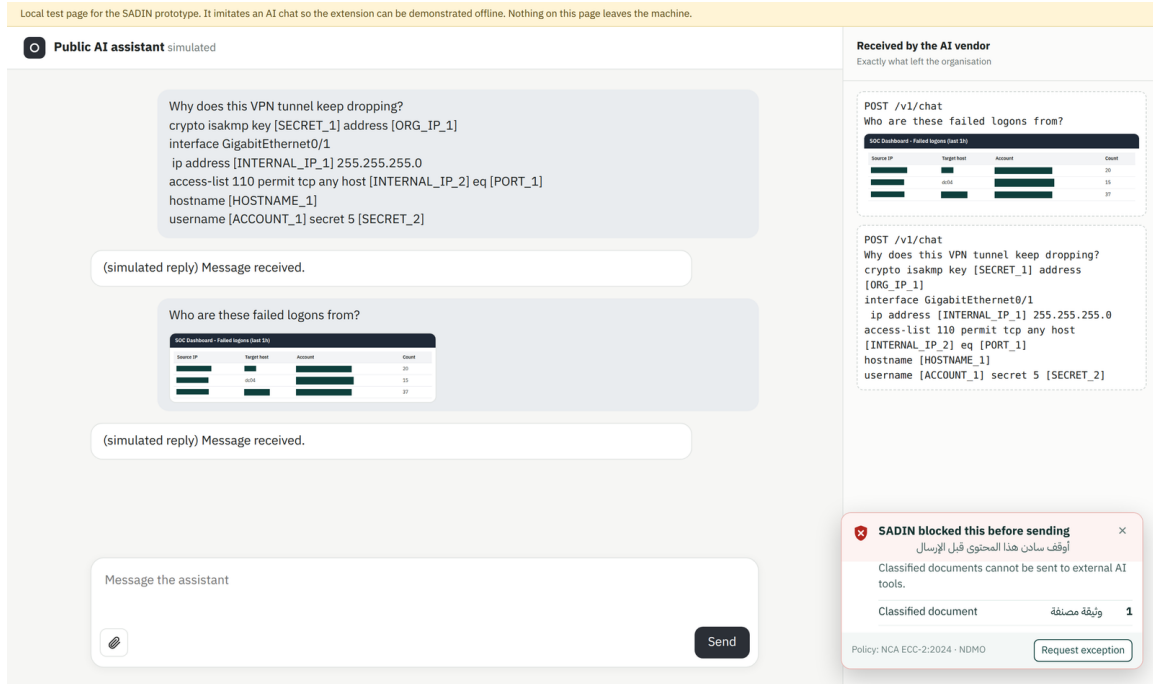


Figure 7. A classified document is stopped before sending; the employee sees the reason and can request an exception.

13.3 Test method

- **Text.** A development set (111 sensitive messages with 155 labelled items, and 100 clean business prompts) was used while building the detectors. A separate held-out set (30 sensitive messages with 51 items, and 50 clean prompts, with different phrasings and formats) was frozen and run once on engine v0.3.0, with no tuning afterwards.
- **Arabic.** Two Arabic sets in Saudi workplace phrasing, formal and colloquial, with Arabic-Indic and Western digits and mixed Arabic and English: a development set (34 sensitive messages, 47 items, 38 clean prompts) and a held-out set (30 sensitive messages, 36 items, 40 clean prompts). The held-out set was written and hashed (SHA-256) before any engine change, run once on the old engine as a baseline, and run once after the changes (engine v0.4.0).
- **Screenshots.** Twenty images generated from templates (SOC dashboard, router terminal, HR portal, and Arabic memos marked with a classification stamp or a written classification line), seeded with 72 known values. The true on-screen position of each value is taken from the page layout, so masking is scored against the real rectangle, and each masked image is read again by OCR to check nothing is still readable. The reported run used a seed not used in development.
- **Metrics.** An item counts as caught only if a finding of the correct class covers it. A false positive is any finding on a clean prompt. Every redacted output is re-scanned and must not trigger again.

13.4 Results

Metric	Result	Test set
Sensitive items caught in text	86.3% (44 of 51)	English held-out, first run, v0.3.0
Messages flagged	93.3% (28 of 30)	English held-out, first run
Classified markings blocked in text	5 of 6	English held-out, first run
False positives on clean prompts	0 of 50	English held-out, first run
Screenshot values masked	95.8% (69 of 72)	20 screenshots, unseen seed, v0.3.1

Metric	Result	Test set
Values still readable after masking	1 of 72	20 screenshots, unseen seed
Classified Arabic memos blocked	8 of 8 (4 with a stamp, 4 with a written classification line)	20 screenshots, unseen seed
Non-classified images wrongly blocked	0 of 12	20 screenshots, unseen seed
Arabic items caught before the Arabic changes	50.0% (18 of 36)	Arabic held-out, v0.3.1
Arabic items caught after the Arabic changes	100% (36 of 36)	Arabic held-out, first run, v0.4.0
False positives on Arabic clean prompts	1 of 40	Arabic held-out, first run, v0.4.0
Processing time (median)	about 0.01 ms per message; about 0.2 s per 1 MB paste; about 1.7 s per screenshot (maximum 3.6 s)	Same runs

Per class, English held-out set: network details 27 of 29, credentials 9 of 12, account identifiers 3 of 4, classified markings 5 of 6. The seven misses were an SSH port, a WinRM port, a mysql -p password, a password described as “changed to”, a basic-auth password, a username after an Arabic “username” label, and an Arabic phrase meaning “classified document”. They were fixed in v0.3.1; after that fix both English sets score 100% with no false positives, but the held-out set is no longer independent, so **86.3% remains the headline figure**.

Screenshots: the three misses were two short lowercase hostnames (dc01, dc04) and one IP address that OCR read with a corrupted octet. A regression run of the same seed on v0.4.0 masked 71 of 72; because that seed had already been used, it is a check that nothing broke, not a new headline.

Arabic: the one false positive was a genuine question about what the Restricted level means, blocked because it contains a classification phrase:

(وش يعني مستوى التصنيف مقيد في سياسات البيانات؟)

It is reported as it happened and was not tuned away. The held-out set was later run a second time with the same engine and frozen file, with identical results.

Real-browser test (24 September 2026). The actual extension was loaded into Chromium and messages were typed into the test page: an Arabic message with an Arabic-Indic IP address, a port, a username and a password had all four replaced and the Arabic question arrived intact; an ordinary Arabic request (a leave email) passed unchanged; an English mysql command had its IP address and password redacted.

13.5 Bugs the tests found

- **Placeholder loop.** The engine re-detected its own placeholders, so a redacted message could never be sent. Found by the re-scan check and fixed.
- **Passwords inside URLs** were mislabeled as email accounts. Fixed.
- **Arabic port numbers** were never matched because \b does not work in Arabic script. Fixed.
- **Boxed classification stamps** were skipped by OCR page segmentation. Fixed with the colored-ink pass.

13.6 Reproducibility

The source, the frozen test sets, their SHA-256 hashes and every raw result file are published with the prototype. The text results are reproduced with `node eval/run.js --holdout` and `--set=arabic-holdout`, and the screenshot results with `node eval/ocr-eval.js` and the seed 990011. All values in the test sets are fabricated; none is a live credential.

14. Limitations and residual risk

- **Synthetic, team-written test data.** The sets are not a sample of real employee traffic, and the same people wrote the detectors and the tests. The held-out procedure reduces this bias but does not remove it. The Arabic sets are small, so 36 of 36 is an optimistic figure.
- **A photograph of the screen** taken with a personal phone cannot be stopped by any technical control. The answers are policy, awareness and fewer people with access to classified data.
- **OCR misses some values:** short lowercase hostnames, low-resolution images, handwriting and stylized Arabic fonts. Screenshot inspection takes about 1.7 seconds, which suits a paste but not bulk uploads.
- **PDF and Office files** are blocked whole rather than redacted until document parsing arrives, which is safe but can get in the way of legitimate work.
- **Coverage is browser-only** until the endpoint agent: desktop AI apps, IDE assistants and voice are not covered by the prototype.
- **Deliberate evasion** by a determined insider (splitting or encoding a secret) is out of scope for a tool aimed at accidental leakage; long encoded strings are partly caught by the entropy check.
- **Employee privacy.** SADIN processes employee activity; the log is therefore limited to metadata, kept on premises, restricted by role and disclosed to employees.

15. Roadmap

Phase	Scope	Outcome
1. Prototype (done)	Extension with text, file and image interception; Arabic and English engine; on-premises OCR; redact, warn and block; decision log with CEF export; evaluation	Working prototype on Chrome and Edge, tested (Section 13)
2. Pilot	Endpoint agent; Office and PDF parsing and redaction; sensitivity-label integration; console with exception approval	Pilot with one organization on real, consented traffic: observe, then protect, then enforce
3. Identity	Enterprise AI tenant integration; SSO and conditional-access playbook; personal-account blocking	Tenant-level enforcement
4. Gateway	Reverse proxy for unmanaged devices; mobile coverage	Coverage for devices the organization does not manage

16. Alignment with SAIF 2026

SAIF, the Security & Innovation Fair, is organized by the Ministry of Interior in partnership with Tuwaiq Academy [10]. SADIN is entered in **Track 02: Cybersecurity and Defensive Technologies**.

17. Team

Name	Role	Responsibilities
Shahad Helal Alghamdi	Security architecture and detection engine	Policy engine, detectors, compliance mapping, evaluation
Teef Saleh Alghamdi	Extension and inspection service	Browser extension, on-premises service, demonstration

18. Glossary

Term	Meaning
CASB / SSE	Cloud Access Security Broker / Security Service Edge: services that inspect and control traffic between users and cloud applications
CEF	Common Event Format: a text log format that SIEM products ingest
Conditional Access	Identity-provider policies that allow or deny access based on device compliance, location, risk and other signals
DLP	Data Loss Prevention: detecting and stopping sensitive data from leaving the organization
ExtensionInstallForcelist	Chrome and Edge enterprise policy that installs an extension on managed browsers and prevents its removal
Fail closed	Anything that cannot be inspected is blocked rather than allowed
Infostealer	Malware that collects saved passwords, session cookies and other secrets from a browser and sends them to the attacker
Manifest V3	The current Chrome extension platform
OCR	Optical character recognition: reading text from images
Placeholder	The label that replaces a redacted value, such as [SECRET_1] or [INTERNAL_IP_2]
Redaction	Removing or masking the sensitive part of content while letting the rest through
Shadow AI	Use of AI tools by employees without the organization's knowledge or control
SIEM	Security Information and Event Management: the system that collects and analyses security logs
SSO	Single sign-on with the organization's identity provider
Tenant	An organization's own instance of a cloud service, with its own users, data and admin controls

19. References

- [1] National Cybersecurity Authority (NCA). Essential Cybersecurity Controls, ECC-2:2024. Riyadh, 2024.
- [2] National Data Management Office (NDMO), SDAIA. National Data Governance Policies: Data Classification Policy. <https://sdaia.gov.sa/ar/SDAIA/about/Documents/Data%20Classification%20Policy.pdf>
- [3] Group-IB. "Group-IB Discovers 100K+ Compromised ChatGPT Accounts on Dark Web Marketplaces." Press release, 20 June 2023. <https://www.group-ib.com/media-center/press-releases/stealers-chatgpt-credentials/>
- [4] Group-IB. Hi-Tech Crime Trends 2023/2024. February 2024. <https://www.prnewswire.com/news-releases/group-ib-reveals-hi-tech-crime-trends-2324-surge-in-ransomware-against-backdrop-of-growing-ai-macos-threats-302075538.html>
- [5] The Economist Korea, 30 March 2023; Bloomberg, "Samsung Bans Staff's AI Use After Spotting ChatGPT Data Leak," 2 May 2023.
- [6] Fast Company, July 2025, investigation of shared ChatGPT conversations indexed by Google; OpenAI's removal of the discoverability option as reported by PC Gamer, August 2025. <https://www.pcgamer.com/software/ai/chatgpt-removes-the-ability-for-conversations-to-be-displayed-by-search-engines-as-nearly-4-500-conversations-indexed-by-google/>
- [7] Google, Chrome for Developers. "Replace blocking web request listeners" (Manifest V3; webRequestBlocking remains available to policy-installed extensions). <https://developer.chrome.com/docs/extensions/develop/migrate/blocking-web-requests>
- [8] OWASP. Top 10 for Large Language Model Applications 2025: LLM02 Sensitive Information Disclosure.
- [9] Tesseract OCR, open-source OCR engine. <https://github.com/tesseract-ocr/tesseract>
- [10] Saudi Press Agency. "Registration Opens for Global Security and Innovation Fair and Competition," 22 July 2026. <https://www.spa.gov.sa/en/N2639485>
- [11] SAIF 2026 participant guide (official competition guide supplied to participants).